2.1 – Centro de Operações de Segurança Moderno

2.1 – Elementos de um SOC: A defesa contra ameaças atuais requer uma abordagem formal, estruturada e disciplinada. Isso é realizado através de um Centro de Operações de Segurança (SOC). São responsáveis por uma ampla gama de serviços, desde monitoramento e gerenciamento, soluções contra ameaças e segurança hospedada, que atendem as necessidades dos clientes. Os SOCs podem ser totalmente internos operados por uma empresa, ou podem ser contratados de uma fornecedora de segurança como os Managed Security Services.

Os principais elementos de um SOC são: Processamento, Pessoal e Tecnologia.

2.1.2 – Pessoas no SOC: As funções de trabalho de um SOC evoluem constantemente. Os trabalhos nessa área são divididos por níveis, de acordo com a experiência e as responsabilidades necessárias de cada um. Os primeiros níveis são iniciais e os de terceiro nível exigem ampla experiência.

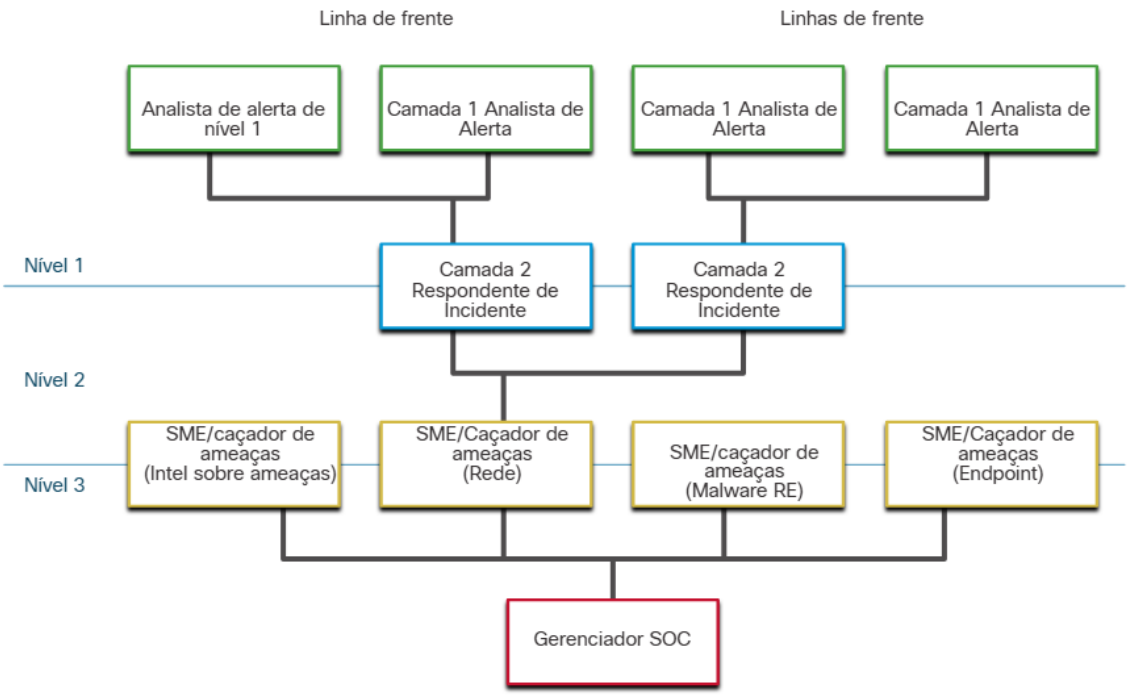
Analista de Alerta de Nível 1: Monitoram alertas recebidos, verificam se um incidente é verdadeiro e se ocorreu encaminham para o nível 2, caso seja preciso.

Respondente a Incidentes Nível 2: São responsáveis pela investigação aprofundada de incidentes e aconselham a correção ou a ação a serem tomadas.

Caçador de Ameaças de Nível 3: Possuem habilidades de nível especializado em rede, endpoit, inteligência contra ameaças e engenharia reversa de malware. Rastreiam processos do malware para determinar o impacto e como pode ser removido. Buscam ameaças potenciais e implementam ferramentas de detecção de ameaças. Buscam ameaças presentes na rede que ainda não foram detectadas.

Gerente de SOC: Gerencia todos os recursos do SOC e serve como ponto de contato para a organização ou cliente maior.

Interação das funções entre si, na imagem abaixo:

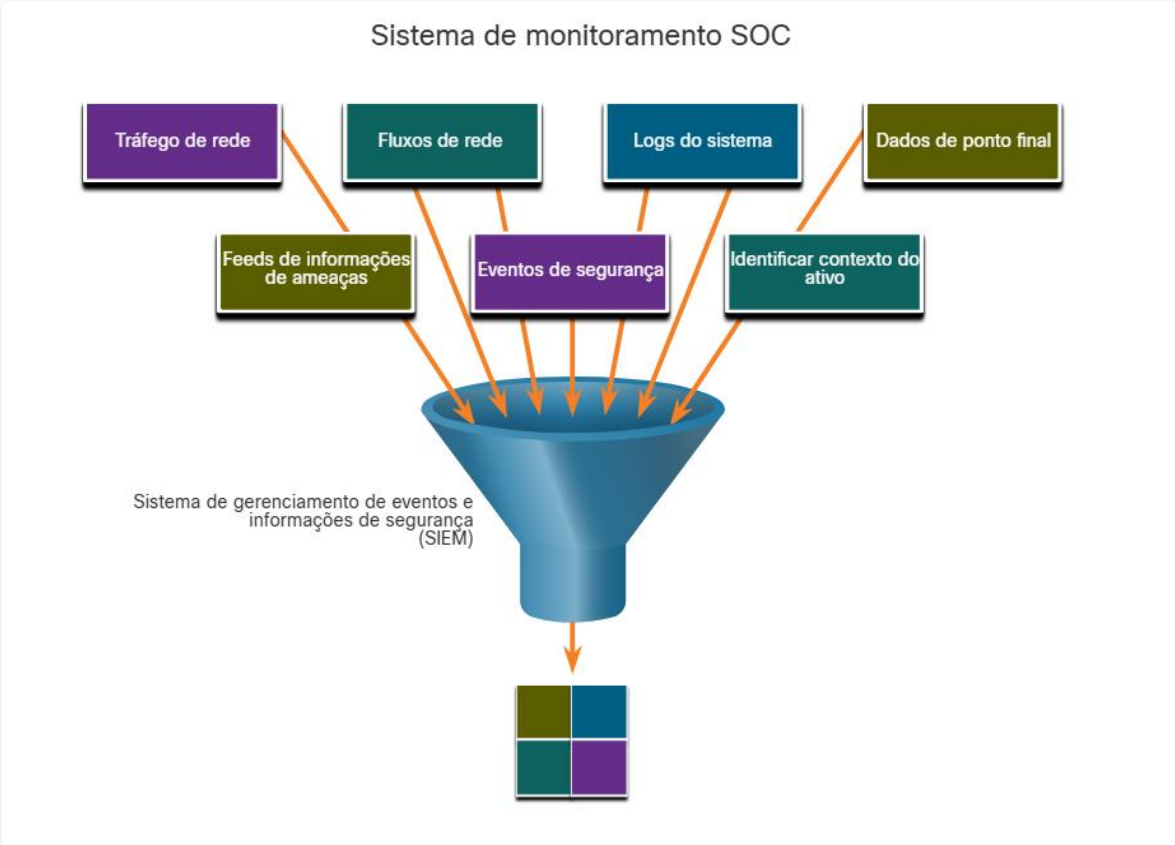


2.1.3 – Processo no SOC: O analista de segurança vivencia o dia com o monitoramento de filas de alertas de segurança. Utiliza um sistema de tíquetes que atribui um alerta a determinada fila. O software pode gerar alertas com alarmes falsos, sendo assim o trabalho de uma analista é classificar se o alerta representa um verdadeiro incidente de segurança.

Caso um tíquete não possa ser resolvido, o mesmo é encaminhado para um respondente de incidente nível 2 para uma investigação e correção mais profunda. Caso o nível 2 não resolva é direcionado para o nível 3.

2.1.4 – Tecnologias no SOC - SIEM: O SOC precisa de um Security Information And Event Management System (SIEM) – Sistema de gerenciamento de eventos e informações de segurança. O SIEM monitora todos os dados gerados por firewall, dispositivos de rede, sistemas de detecção de intrusões e outros dispositivos.

Podem coletar e filtrar dados, detectar e classificar ameaças e analisar e investigar ameaças. Também gerenciam recursos e implementam medidas preventivas que lidam com ameaças futuras. As tecnologias SIEM incluem: Coleta e correlação e análise de eventos, monitoramento de segurança, controle de seguranças, gerenciamento de logs, avaliação e controle de vulnerabilidades e inteligência de ameaças.



2.1.5 – Tecnologias no SOC – SOAR: SIEM e orquestração de segurança, automação e resposta (SOAR) possuem recursos que se completam. Equipes grandes de operações de segurança (SecOps) usam ambas as tecnologias para otimizar seu SOC. 15% das organizações com uma equipe de mais de 5 pessoas utilizarão o SOAR até o final de 2020.

Essas plataformas agregam, correlacionam e analisam alertas, porém o diferencial é que o SOAR integra inteligência contra ameaças automatizando fluxos de trabalho de investigação e resposta de incidentes com base em manuais desenvolvidos pela equipe de segurança.

Funções do SOAR: Reunir dados de cada componente do sistema, fornecer ferramentas que permitam que os casos sejam pesquisados, avaliados e investigados, enfatizar a integração como meio de automatizar fluxos de trabalho complexos de resposta a incidentes, permitindo respostas mais rápidas e estratégias de defesa adaptativas e por fim incluir playbooks predefinidos que permitem a resposta automática a ameaças especificas.

Os SIEM produzem muitos alertas que são inviáveis para a equipe de SecOps investigar, portanto a utilização do SOAR processa muitos desses alertas automaticamente, permitindo que o pessoal de segurança se concentre em outras atividades mais complexas e potencialmente mais prejudiciais.

2.1.6 Métricas SOC: Métricas ou indicadores de desempenho (KPI) podem ser projetadas para medir diferentes aspectos específicos do desempenho do SOC. Dessa forma cinco métricas são comumente usados como métricas SOC. Essas métricas descrevem o desempenho geral, porém não apresentam uma imagem precisa da operação SOC, pois existe muitas ameaças à segurança cibernética.

Métricas comuns compiladas pelo Gerente de SOC:

Tempo de Permanência: O período de tempo que os atores da ameaça têm acesso a uma rede antes de serem detectados e seu acesso é interrompido.

Tempo médio para detectar (MTTD): Tempo médio que o pessoal do SOC leva para identificar incidentes de segurança válidos na rede.

Tempo médio para responder (MTTR): Tempo médio necessário para parar e corrigir um incidente de segurança.

Tempo médio para conter (MTTC): O tempo necessário para impedir que o incidente causa mais danos aos sistemas ou dados.

Tempo de controle: O tempo necessário para impedir a propagação de malware na rede.

2.1.7 Segurança corporativa e gerenciada: Redes de médio e grande porte se beneficiam ao incluir um SOC de nível empresarial. Muitas organizações maiores terceirizam pelo menos parte das operações SOC para um provedor de soluções de segurança.

Uma dessas equipes é a CISCO, no qual tem uma equipe de especialistas que ajudam a garantir a resolução de incidentes oportunas e precisa, como Serviço Cisco Smart Net Total Care para resolução rápida de problemas, Equipe de resposta a incidentes de segurança do produto (PSIRT), Equipe de resposta a incidentes de segurança de computadores (CSIRT), Serviços gerenciados CISCO, Operações Táticas Cisco (TacOps) e Programação de Segurança Física e Segurança da Cisco.

2.1.8 DevSecOps: Significa Desenvolvimento, Segurança e Operações. É uma parte que integra a segurança no processo de desenvolvimento e operações, com o objetivo de fazer da segurança uma parte integral do ciclo de vida do software, visa reduzir as vulnerabilidades e melhorar a segurança geral das aplicações, sistemas e ambientes.

DevSecOps Oferece:

Remediação mais rápida: Problemas de segurança são identificados cedo, reduzindo o tempo e custo para corrigi-los.

Risco reduzido: Verificações de segurança contínuas minimizam as chances de vulnerabilidades chegarem a produção.

Maior Eficiência: A automação das tarefas de segurança permite que as equipes se concentrem em suas responsabilidades principais enquanto garantem que a segurança não seja negligenciada.

Melhoria na colaboração: Responsabilidade compartilhada, melhora na comunicação e o trabalho entre desenvolvedores, segurança e equipes de operações.

2.1.9 Segurança versus Disponibilidade: A maioria das redes empresariais devem estar funcionando o tempo todo, dessa forma a disponibilidade da rede deve ser preservada. Cada empresa ou setor tem uma tolerância limitada para o tempo de inatividade da rede. Essa tolerância é baseada em uma comparação do custo do tempo de inatividade em relação ao custo de garantia contra o tempo de inatividade.

Exemplo: Uma pequena empresa de varejo com apenas um local, pode ser tolerável ter apenas um roteador como um único ponto de falha. Porém se nessa empresa a maioria das vendas for online o proprietário pode decidir fornecer um nível de redundância para garantir que uma conexão esteja sempre disponível.

O tempo de atividade preferencial geralmente é medido no número de minutos de inatividade em um ano. Uma atividade de cinco noves significa que a rede está acima de 99,999% do tempo ou inativa por não mais de 5 minutos por ano. Quatro noves seria um tempo de inatividade de 53 minutos por ano.

Disponibilidade %	Tempo de inatividade
99.8%	17,52 horas
99,9% ("três noves")	8,76 horas
99,99% ("quatro noves")	52,56 minutos
99,999% ("cinco noves")	5.256 minutos
99,9999% ("seis noves ")	31,56 segundos
99,99999% ("sete noves ")	3,16 segundos

A segurança não pode ser tão forte que interfira com as necessidades dos funcionários ou funções empresarias. É sempre um trade off entre forte segurança e permitir um funcionamento eficiente dos negócios.

2.2 – Tornando-se um Defensor

2.2 – Certificações: Existe uma variedade de certificações de segurança cibernética que são relevantes para carreiras em SOCS estão disponíveis em várias organizações diferentes.

Cisco Certified CyberOps Associate: Fornece um primeiro passo valioso na aquisição do conhecimento e das habilidades necessárias para trabalhar com uma equipe de SOC.

Certificação de analista de segurança cibernética CompTIA (CYSA+): É uma certificação profissional de T.I neutra no fornecedor. Valida os conhecimentos e as habilidades necessárias para configurar e usar ferramentas de detecção de ameaças, realizar análises de dados, interpretar os resultados para identificar vulnerabilidades, ameaças e riscos para uma organização. O objetivo final é a capacidade de proteger aplicativos e sistemas dentro de uma organização.

Certificação ISC: É a organização internacional que oferece a altamente aclamada certificação CISSP. Oferecem uma gama de outras certificações para várias especialidades em segurança.

Certificação Global de Garantia de Informações (GIAC): Uma das mais antigas organizações de certificação de segurança. Oferece certificações em sete categorias.

2.2.1 Aprofundar meus conhecimentos: Importante ter a obtenção de um diploma técnico ou bacharel.

Programação em Python: É importante ter uma linguagem de programação pois é muito utilizado por analistas de segurança cibernética, python é uma linguagem de programação popular para sistemas baseados em Linux e redes definidas por software (SDN).

Habilidades Linux: Linux é amplamente utilizado em SOCS e outros ambientes de rede e segurança. Habilidades em Linux são uma adição valiosa ao seu conjunto de habilidades enquanto você trabalha para desenvolver uma carreira em segurança.

2.2.2 Informações sobre carreira – sites de emprego:

Indeed.com

Anunciado como o site de empregos número 1 do mundo, o Indeed.com atrai mais de 180 milhões de visitantes únicos por mês de mais de 50 países diferentes. Indeed.com é verdadeiramente um site de empregos mundial. Ajuda empresas de todos os tamanhos a contratar os melhores talentos e oferece a melhor oportunidade para quem procura emprego.

CareerBuilder.com

O CareerBuilder atende a muitas empresas grandes e de prestígio. Como resultado, esse site atrai candidatos específicos que normalmente têm mais educação e credenciais mais altas. Os empregadores que postam no CareerBuilder geralmente obtêm mais candidatos com diplomas universitários, credenciais avançadas e certificações do setor.

USAJobs.gov

O governo federal dos Estados Unidos publica todas as vagas no site USAJobs.

Glassdoor

O site glassdoor.com fornece informações salariais para diferentes tipos de trabalho, empresas e locais. Procure por "analista de segurança cibernética" para ver os salários e os requisitos para as vagas atuais.

2.2.3 – Obtendo experiência: Estágios são uma excelente forma de entrar no campo de segurança cibernética, é um local que agrega experiência, amplia contatos.

Bolsas e prêmios: Cisco e Infosec introduziram programas de bolsas e prêmios que fornecem dinheiro aos alunos que atendem aos requisitos de qualificação.

Agências Temporárias: Ajudam a polir o currículo e fazer recomendações sobre habilidades adicionais que possa ser preciso obter para se tornar mais atraente para potenciais empregadores. Agencias temporárias usam de 90 dias para testar a pessoa e se o mesmo for compatível a organização pode oferecer um cargo efetivo.